

1.1 Introduction to Data Security and Privacy

In the modern digital era, data has emerged as the most valuable asset for organizations, governments, and individuals. However, the proliferation of data collection and processing brings significant risks. Understanding the distinction and the intersection between **Data Security** and **Data Privacy** is the foundational step for any Computer Science professional.

1.1.1 Defining Data Security

Data Security refers to the collective set of processes, technologies, and practices designed to protect data from unauthorized access, corruption, theft, or destruction throughout its entire lifecycle. The primary focus of security is the **protection of the container and the content** from external and internal threats.

The core of Data Security is governed by the **CIA Triad**:

1. **Confidentiality:** Ensuring that sensitive information is accessed only by authorized users. Mechanisms include encryption, access control lists (ACLs), and two-factor authentication.
2. **Integrity:** Ensuring that data remains accurate, consistent, and unaltered during storage or transmission. Mechanisms include digital signatures, hash functions, and checksums.
3. **Availability:** Ensuring that data and security systems are available to authorized users when needed. This involves protecting against Denial of Service (DoS) attacks, ensuring hardware redundancy, and maintaining robust backup systems.

1.1.2 Defining Data Privacy

Data Privacy (or Information Privacy) is a branch of data protection that deals with the proper handling of data—consent, notice, and regulatory obligations. More specifically, it concerns the rights of individuals to control how their **Personally Identifiable Information (PII)** is collected, used, shared, and stored.

While security focuses on *how* to protect data, privacy focuses on *why* and *what* data should be collected in the first place. A system can be secure (e.g., encrypted) but still violate privacy (e.g., if a company sells your encrypted location history to a third party without your consent).

1.1.3 The Intersection: Privacy vs. Security

The relationship between the two can be summarized as follows: **You can have security without privacy, but you cannot have privacy without security.**

- **Privacy without Security:** If a company promises not to sell your data (Privacy Policy) but stores it in an unencrypted database that gets hacked, your privacy is lost because security failed.
- **Security without Privacy:** A surveillance state may have incredibly secure databases (Security), but it collects data on every citizen's movement without their consent (Privacy violation).

1.2 Fundamentals of Database Systems in a Security Context

A **Database Management System (DBMS)** is the software layer that interacts with end-users, applications, and the data itself to capture and analyze information. In the context of this course, we view the database not just as a storage tool, but as a **target** and a **fortress**.

1.2.1 Data Representation and Storage

Data in a database is typically structured in one of two ways, each posing different security challenges:

1. **Relational Databases (RDBMS):** Data is stored in tables (rows and columns). Security is managed via **Schemas**. The primary security mechanism here is **Grant/Revoke** permissions on specific tables or views.
2. **Non-Relational (NoSQL):** Data is stored as documents (JSON), graphs, or key-value pairs. These systems often prioritize "Availability" and "Partition Tolerance" (from the CAP Theorem) over strict "Consistency," which can lead to "stale" data being exposed if security updates aren't propagated instantly.

1.2.2 The ACID Properties and Security

For a database to be reliable, it must follow the **ACID** properties. Security plays a role in each:

- **Atomicity:** Transactions must be "all or nothing." A security breach during a transaction must not leave the data in a partially modified, vulnerable state.
- **Consistency:** Data must move from one valid state to another. Constraints (like foreign keys) prevent "orphaned" data that could be exploited.
- **Isolation:** Concurrent transactions should not interfere. If isolation fails, a user might "see" the intermediate, sensitive data of another user (a **Race Condition**).
- **Durability:** Once committed, data remains even in a system failure. This requires secure, encrypted backups.

1.2.3 Common Database Security Threats

1. **SQL Injection (SQLi):** An attacker inserts malicious SQL code into input fields to manipulate the database. Example: Entering ' OR 1=1 -- into a login field to bypass authentication.
2. **Inference Attacks:** A user without access to specific sensitive records "infers" the data by running aggregate queries.
 - *Example:* A user cannot see Bob's salary. However, they can query the "Average Salary of the IT Department." If they know the average before and after Bob was hired, they can calculate Bob's exact salary.
3. **Privilege Escalation:** A user with low-level permissions exploits a bug to gain "Admin" or "Superuser" status.
4. **Excessive Privilege:** Users are granted more access than required for their job, increasing the "attack surface."

1.3 Exploratory Data Analysis (EDA) for Privacy and Security

Exploratory Data Analysis (EDA) is an approach to analyzing data sets to summarize their main characteristics, often with visual methods. In the field of Data Privacy, EDA is the **diagnostic phase**. Before we can protect a dataset, we must analyze its structure to identify where the "privacy leaks" are.

1.3.1 The Goal of EDA in Privacy-Preserving Data Science

In a standard data science pipeline, EDA is used to find patterns for machine learning. In **Privacy-Preserving EDA**, the goals are:

1. **Identify PII (Personally Identifiable Information):** Identifying columns like Name, Social Security Numbers, or Fingerprint hashes.
2. **Identify Quasi-Identifiers:** These are attributes that are not unique identifiers on their own but can be combined to identify an individual.
 - *Example:* (Zip Code + Gender + Date of Birth) can uniquely identify approximately 87% of the US population.
3. **Detect Outliers:** Outliers are often the most "identifiable" individuals in a dataset. If someone is 7 feet tall in a small town, "Height" becomes a unique identifier for them.

1.3.2 Statistical Techniques in EDA

To understand the "leakage" of a dataset, we use several statistical measures:

A. Descriptive Statistics

- **Measures of Central Tendency (Mean, Median, Mode):** These provide a "general" view. However, revealing the Mean can sometimes lead to the "Inference Attack" mentioned earlier.
- **Measures of Dispersion (Variance, Standard Deviation, Range):** High variance in a sensitive field (like "Debt") suggests that individuals are highly distinguishable, making them harder to anonymize.

B. Data Distribution Analysis

- **Histograms:** Used to see the frequency of values. If a histogram shows a very "thin" tail (few people with extreme values), those people are at high risk of re-identification.
- **Box Plots:** Excellent for identifying **outliers**. In a privacy context, an outlier is a "privacy hazard."
- **Scatter Plots:** Used to find correlations. If two attributes are highly correlated (e.g., Professional Title and Salary), protecting one but revealing the other results in a privacy breach.

1.3.3 The "Curse of Dimensionality" in Privacy

As the number of features (columns) in a database increases, the data becomes "sparse." In a high-dimensional space, every individual becomes an "outlier."

EDA helps us realize that the more data we collect about a person, the more impossible it becomes to hide

them in a crowd. This is why EDA is essential for **Dimensionality Reduction** (e.g., PCA) before a dataset is released to the public.

1.4 The Lifecycle of Data: A Security Perspective

To master the fundamentals, one must understand how data moves through a system. This is known as the **Data Life Cycle**:

1. **Generation/Collection:** The moment data is created.
 - *Privacy Concern:* Is there "Informed Consent"?
 - *Security Concern:* Is the data collected over an encrypted channel (SSL/TLS)?
 2. **Storage:** Data at rest.
 - *Security Concern:* Are the hard drives encrypted (AES-256)? Is there a redundancy plan (RAID)?
 3. **Usage/Processing:** When the data is being analyzed.
 - *Security Concern:* This is the most vulnerable state. Data must be decrypted in RAM to be processed.
 4. **Sharing/Transfer:** Sending data to third parties.
 - *Privacy Concern:* Does the recipient follow the same privacy laws?
 5. **Archival:** Long-term storage of inactive data.
 6. **Destruction/Disposal:** The final stage.
 - *Security Concern:* "Logical Deletion" (pressing delete) is not enough. "Physical Destruction" or "Cryptographic Shredding" (deleting the encryption key) is required to ensure data cannot be recovered.
-

1.5 Taxonomy of Data Identifiers

In any exam regarding Data Privacy, you must be able to categorize data types correctly. EDA helps us sort data into these four buckets:

1. **Direct Identifiers:** Information that relates specifically to an individual.
 - *Examples:* Full Name, Passport Number, Email Address.
 - *Action:* These must be **redacted** or **hashed** in any privacy-preserving system.
2. **Quasi-Identifiers (QIs):** Information that does not identify a person alone but can be linked with external data to re-identify them.
 - *Examples:* Birthdate, Gender, ZIP code, Race.

- *Action:* These must be **generalized** (e.g., changing a specific age to an age range like 20-30).
 - 3. **Sensitive Attributes:** Information that the user wants to keep private but does not necessarily identify them.
 - *Examples:* Medical diagnosis, Salary, Religious belief, Criminal record.
 - *Action:* We want to release the *statistics* of these attributes without linking them to QIs.
 - 4. **Non-Sensitive Attributes:** Information that poses no risk.
 - *Examples:* The color of the hospital building where a patient was treated.
-

1.6 Key Regulatory Concepts (Preview of Unit I Laws)

The fundamentals of privacy are now codified into law. When performing EDA or designing a database, two concepts from global laws (like GDPR) are paramount:

1. **Privacy by Design (PbD):** This philosophy states that privacy cannot be an "add-on." It must be integrated into the system from the very first line of code. It means the "Default" setting of any database should be the most private one.
2. **Data Minimization:** A fundamental principle stating that a company should only collect the *minimum* amount of data necessary to fulfill a specific purpose. EDA often reveals that organizations collect "junk data" that they don't need, which only serves to increase their security liability.

2.1 Data Representation and Storage: The Security Perspective

In computer science, **Data Representation** refers to the methods used to represent information internally in a computer system, while **Storage** refers to the physical or logical placement of that data. From a security standpoint, the way data is represented dictates its vulnerability, and how it is stored determines its accessibility.

2.1.1 Logical vs. Physical Data Representation

To secure a system, one must understand the layers of data:

1. **Physical Level:** The actual bits on magnetic or solid-state drives. Security here involves **Full Disk Encryption (FDE)** and physical access controls to data centers.
2. **Conceptual/Logical Level:** How data is structured (Tables, Relationships, Objects). Security involves defining schemas that hide sensitive attributes from certain user classes.
3. **View Level (External):** The highest level of abstraction. This is where **Data Masking** occurs. For example, a customer service representative sees a credit card number represented as **** * 1234.

2.1.2 Structured, Semi-Structured, and Unstructured Data Security

- **Structured Data (SQL):** Highly organized in rows and columns. Security is easier to implement through **Relational Algebra** and access controls. However, it is highly susceptible to **SQL Injection**.
- **Semi-Structured Data (XML, JSON):** Common in web services. Representation is flexible. Security risks include **XML External Entity (XXE)** attacks, where an attacker manipulates the data representation to read local files.
- **Unstructured Data (PDFs, Images, Videos):** This is the hardest to secure because "content-aware" security is difficult. A company might secure a database but leave sensitive contracts in unencrypted PDF format on a shared drive.

2.1.3 Secure Data Storage Mechanisms

1. **Transparent Data Encryption (TDE):** This is a technology used by DBMS providers (like Oracle or SQL Server) to encrypt the database files on the hard drive. It protects data "at rest." If a physical drive is stolen, the data is unreadable without the master key.
2. **Cryptographic Salting and Peppering:** When representing passwords in storage, they must never be stored in "Plaintext."
 - **Salt:** A random string added to a password before hashing to prevent **Rainbow Table** attacks.
 - **Pepper:** A secret constant added to the hash, usually stored in a different location (like an HSM—Hardware Security Module).
3. **Object-Based Storage Security:** In cloud environments (like AWS S3), data is stored as "objects." Security is managed via **IAM (Identity and Access Management)** policies rather than traditional file permissions.

2.2 Authentication and Authorization: The Pillars of Identity

Authentication and Authorization are the twin pillars of Access Control. Though often used interchangeably in casual conversation, they serve distinct technical functions.

2.2.1 Authentication (AuthN): "Who are you?"

Authentication is the process of verifying the identity of a user, device, or system. It is the digital equivalent of checking a passport.

The Three Factors of Authentication:

1. **Knowledge Factor (Something you know):** Passwords, PINs, or answers to security questions. (Weakest factor, as it can be phished or guessed).
2. **Possession Factor (Something you have):** Smart cards, hardware tokens (YubiKey), or OTPs (One-Time Passwords) sent to a mobile device.
3. **Inherence Factor (Something you are):** Biometrics such as fingerprints, retina scans, facial recognition, or voice patterns. (Hardest to steal, but impossible to "reset" if the biometric data is compromised).

Multi-Factor Authentication (MFA):

MFA requires at least two of the three factors above. It is based on the principle that even if one factor is compromised (e.g., a password is leaked), the attacker cannot gain access without the second factor (e.g., the user's physical phone).

2.2.2 Authorization (AuthZ): "What are you allowed to do?"

Once a user is authenticated, Authorization determines their level of access. For example, an employee is authenticated to enter the building but is not authorized to enter the Server Room.

Common Authorization Models:

1. **Discretionary Access Control (DAC):** The "Owner" of the data decides who has access. This is common in Windows/Linux file systems. It is flexible but risky, as a user can accidentally grant access to a malicious actor.
 2. **Mandatory Access Control (MAC):** Access is based on "Clearance Levels" (Secret, Top Secret). The system, not the user, determines access. This is used in high-security military environments.
 3. **Role-Based Access Control (RBAC):** Access is based on the user's job function. (e.g., "Accounting" role can see payroll; "IT" role cannot). This is the industry standard for enterprise databases.
 4. **Attribute-Based Access Control (ABAC):** The most granular model. Access is granted based on a combination of attributes (User's role + Time of day + IP Address + Location).
-

2.3 Database Security: Defending the Core

Database security is a specialized field that focuses on protecting the database engine and the data it contains.

2.3.1 The "Gold Standard" of Database Security (The Pentagon of Defense)

To provide "Defense in Depth," database security must be implemented at five levels:

1. **Physical Security:** Preventing unauthorized physical access to the server.
2. **Network Security:** Using Firewalls and SSL/TLS to encrypt data in transit between the application and the database.
3. **Operating System Security:** Hardening the OS on which the database runs (disabling unnecessary services/ports).
4. **DBMS Security:** Implementing user accounts, passwords, and roles within the database software.
5. **Data Security:** Encrypting specific sensitive columns (e.g., Credit Card numbers) using **Field-Level Encryption**.

2.3.2 Internal Database Security Mechanisms

- **Views:** A View is a "virtual table." Instead of giving a user access to a whole table with 50 columns, you create a View containing only the 5 columns they need. This adheres to the **Principle of Least Privilege**.

- **Stored Procedures:** These are pre-compiled SQL codes. By forcing users to interact with the database via stored procedures rather than writing raw SQL, you eliminate the risk of **SQL Injection**.
- **Triggers:** A trigger is a script that runs automatically when a certain action (Insert, Update, Delete) occurs. They are used for **Auditing**—logging exactly who changed what data and when.
- **Virtual Private Database (VPD):** A mechanism that adds a dynamic "WHERE" clause to every query a user runs. For example, a doctor querying the "Patients" table will automatically only see the patients assigned to *them*.

2.3.3 Advanced Database Threats

1. **Inference Attacks:** As discussed in EDA, this is when a user combines non-sensitive data to discover sensitive data.
 - *Countermeasure:* **Cell Suppression** (hiding certain cells in a query result) or **Noise Addition**.
2. **Aggregation Attacks:** A user is authorized to see individual records but "aggregates" them to see a bigger picture they aren't authorized to know (e.g., calculating total company revenue when they only have access to regional sales).
3. **SQL Injection (Deep Dive):**
 - **Tautology-based:** ' OR 1=1 -- (Always true, bypasses login).
 - **Union-based:** Using the UNION keyword to join the results of a legitimate query with a sensitive table (like Users).
 - **Blind SQLi:** The attacker asks the database "True/False" questions based on how long the page takes to load.

2.4 Integration: How Representation, Auth, and DB Security Work Together

To understand the full scope, consider a banking application's login process:

1. **Data Representation:** The database stores your password as a **Salted Hash** (Represented securely).
 2. **Authentication:** You enter your username and password. The system hashes your input and compares it to the stored hash. You then enter a code from your phone (**MFA**).
 3. **Authorization:** You are granted a "Customer" **Role (RBAC)**.
 4. **Database Security:** When you click "View Balance," the database uses a **View** to ensure you only see your account ID, and a **VPD** ensures the query results are filtered to only show accounts owned by your UserID.
-

2.5 Detailed Comparison Table for Exam Reference

Feature	Authentication (AuthN)	Authorization (AuthZ)
Question	Who are you?	What can you do?
Timing	Happens first.	Happens after AuthN.
Method	Passwords, Biometrics, OTPs.	RBAC, ACLs, Policies.
Transmission	Credentials passed through headers/forms.	Tokens (like JWT) containing "Claims" or "Permissions."
Failure Result	401 Unauthorized (Error).	403 Forbidden (Error).

3.1 Historical Context: The Right to Privacy as a Fundamental Right

The foundation of modern data privacy law in India was not a statute passed by Parliament, but a landmark judgment by the Supreme Court.

3.1.1 Justice K.S.[\[1\]](#) Puttaswamy (Retd.) v. Union of India (2017)

Until 2017, the Indian Constitution did not explicitly grant a "Right to Privacy." This changed with the nine-judge bench verdict in the *Puttaswamy* case (often called the Privacy Judgment).

- **The Verdict:** The Court unanimously held that the **Right to Privacy is a Fundamental Right** protected under Article 21 (Right to Life and Personal Liberty) and Part III of the Constitution.
- **The Three-Pronged Test:** The Court ruled that any state interference with privacy must meet three criteria:
 1. **Legality:** It must be backed by a clear law.
 2. **Legitimate Aim:** It must serve a specific state interest (e.g., national security).
 3. **Proportionality:** The extent of interference must be proportional to the objective sought.
- **Significance:** This judgment forced the Government to draft a comprehensive data protection law, leading eventually to the DPDP Act of 2023.

3.2 The Information Technology (IT) Act, 2000 (As Amended)

The IT Act is the "Mother Act" for all things digital in India. It was enacted to facilitate e-commerce and give legal recognition to electronic records.[\[2\]](#)[\[3\]](#)

3.2.1 Key Objectives

- 1. **Legal Recognition:** To grant electronic records and digital signatures the same status as paper-based documents.[\[4\]](#)
- 2. **Framework for E-Commerce:** To create a secure environment for online transactions.
- 3. **Cyber-Crime Regulation:** To define offenses and prescribe penalties for digital misconduct.[\[2\]](#)[\[5\]](#)

3.2.2 Critical Sections for Data Security

Section	Subject Matter	Technical Implication
Section 43	Penalty for damage to computer system	Penalties for hacking, introducing viruses, or unauthorized data extraction.
Section 43A	Compensation for failure to protect data	Mandates that companies maintaining "Sensitive Personal Data" (SPDI) must follow "Reasonable Security Practices." [1]
Section 66	Computer-related offenses	If the acts in Section 43 are done "fraudulently or dishonestly," they become criminal offenses.
Section 66C	Identity Theft	Penalizes the fraudulent use of another’s digital signature or password.
Section 66D	Cheating by Personation	Specifically targets phishing and social engineering scams.
Section 66E	Violation of Privacy	Penalizes capturing or transmitting private images of a person without consent.
Section 69	Interception/Decryption	Grants Government power to monitor/decrypt data for national security.
Section 70	Protected Systems	Deals with the security of "Critical Information Infrastructure" (CII).
Section 72A	Disclosure in breach of contract	Penalizes service providers who disclose personal data in violation of a lawful contract.

3.2.3 The Schedules of the IT Act[\[4\]](#)[\[5\]](#)

- **Schedule 1:** Lists documents where the IT Act does **not** apply (e.g., Wills, Negotiable Instruments like Cheques, Power of Attorney). These still require physical paper.
 - **Schedule 2:** Details the methods of authentication for electronic signatures.
-

3.3 The Digital Personal Data Protection (DPDP) Act, 2023[\[6\]](#)[\[7\]](#)

Enacted on August 11, 2023, the DPDP Act is India's first standalone data privacy law. It is designed to be "principle-based" rather than prescriptive.

3.3.1 The Seven Pillars of the Act[\[5\]](#)

1. **Lawful Use:** Data can only be processed for a purpose for which the individual has given consent, or for "certain legitimate uses."
2. **Purpose Limitation:** Organizations must use the data only for the specific reason it was collected.
3. **Data Minimization:** Organizations should only collect the data that is absolutely necessary for the task.
4. **Accuracy:** Organizations must ensure that the personal data of individuals is accurate and up to date.
5. **Storage Limitation:** Data must be deleted once its purpose has been served.
6. **Integrity and Confidentiality:** Data must be protected against unauthorized processing or accidental loss through technical safeguards.
7. **Accountability:** The entity collecting the data (the Data Fiduciary) is responsible for any breach, even if it happens at a third-party processor's end.

3.3.2 Stakeholders in the Ecosystem

- **Data Principal:** The individual (natural person) whose data is being collected.
- **Data Fiduciary:** The entity (company or state) that determines the *purpose* and *means* of processing.
- **Significant Data Fiduciary (SDF):** Notified by the Govt based on volume/sensitivity of data. They must appoint a Data Protection Officer (DPO) and conduct Data Protection Impact Assessments (DPIA).[\[1\]](#)
- **Data Processor:** Any entity that processes data *on behalf* of a Data Fiduciary.

3.3.3 Rights of the Data Principal

- **Right to Information:** To get a summary of data being processed.
- **Right to Correction/Erasure:** To fix errors or have data deleted.
- **Right of Grievance Redressal:** To complain to the Fiduciary or the Data Protection Board.
- **Right to Nominate:** To appoint a person to manage data rights in case of death or incapacity.

3.3.4 Penalties

The DPDP Act moves away from prison time for privacy violations and instead imposes massive financial penalties:

- Failure to prevent data breach: Up to **₹250 Crore**.
 - Failure to notify a breach: Up to **₹200 Crore**.
 - Non-fulfillment of obligations toward children: Up to **₹200 Crore**.
-

3.4 Overview of Cyber-Crime Laws: IPC to BNS Transition

On July 1, 2024, the Indian Penal Code (IPC) was replaced by the **Bharatiya Nyaya Sanhita (BNS)**. The BNS modernizes criminal law by explicitly incorporating digital offenses.

3.4.1 Major Cyber-Offenses under BNS

- **Organized Crime (Clause 111):** For the first time, cybercrime committed by a syndicate is classified as "Organized Crime."
- **Cyber Terrorism (Clause 113):** Acts intended to threaten the unity or security of India using computer resources carry a punishment of **Life Imprisonment**.
- **Sexual Harassment/Stalking:** BNS Clauses 75 (Harassment), 77 (Voyeurism), and 78 (Stalking) now explicitly include acts committed via "electronic means."
- **Identity Theft and Forgery:** Clauses 336-340 expand the definition of "Documents" to include "Electronic and Digital Records."

3.4.2 Procedural Changes (BNSS & BSA)

- The Code of Criminal Procedure is now the **Bharatiya Nagarik Suraksha Sanhita (BNSS)**, which mandates the use of audio-video recording for certain police procedures to prevent evidence tampering.
- The Indian Evidence Act is now the **Bharatiya Sakshya Adhinyam (BSA)**. Section 65B (now reflected in BSA) continues to govern the admissibility of electronic records in court, requiring a "Certificate" of authenticity.

3.5 Consumer Protection and E-Commerce Rules

Data privacy is now inextricably linked to consumer rights. The **Consumer Protection Act (CPA), 2019** and the **E-Commerce Rules, 2020** provide the regulatory framework for online shopping and services.[\[8\]](#)

3.5.1 Unfair Trade Practices (UTP)

Misusing a consumer's personal data (e.g., selling it to a third party without clear disclosure) is now classified as an "Unfair Trade Practice."

- **CCPA (Central Consumer Protection Authority):** This body has the power to recall products, order refunds, and investigate "dark patterns"—manipulative UI/UX designs that trick users into sharing more data than intended.

3.5.2 Obligations of E-Commerce Entities

- **Transparency:** They must disclose the "Country of Origin," total price (including taxes), and refund policies.
 - **Grievance Officer:** They must appoint a Grievance Officer who must acknowledge a complaint within 48 hours and resolve it within one month.[\[9\]](#)
 - **Data Protection Dualism:** E-commerce sites must comply with both the CPA (for fair trade) and the DPDP Act (for data privacy).
-

3.6 E-Transaction Laws and E-Governance

Electronic transactions are governed by the interplay of the IT Act and RBI regulations.

3.6.1 Legal Validity of E-Contracts

Under **Section 10A of the IT Act**, a contract formed electronically (via email, "click-wrap," or "shrink-wrap" agreements) is valid and enforceable if it contains:

1. **Offer and Acceptance:** Exchanged via electronic records.
2. **Consent:** Often obtained via "I Agree" checkboxes.[\[1\]](#)
3. **Authenticity:** Proven via IP logs or digital signatures.[\[1\]](#)

3.6.2 RBI Guidelines on Digital Payments

The Reserve Bank of India (RBI) has issued the "Master Direction on Digital Payment Security Controls" (2021) and the "Authentication Directions" (2025):

- **Multi-Factor Authentication (MFA):** All digital payments must have at least two factors of authentication (e.g., Password + OTP).
 - **Risk-Based Checks:** Banks must monitor transactions for "anomalous behavior" (e.g., a sudden large transfer from a new location).
 - **Liability:** If a customer loses money due to a "security breach" on the bank's end (and not the customer's negligence), the bank is liable for the full amount.
-

3.7 Intermediary Guidelines and Digital Media Ethics Code (2021 Rules)[9][10]

Intermediaries (like Google, Facebook, WhatsApp, or Amazon) enjoy "Safe Harbor" protection under **Section 79 of the IT Act**—meaning they aren't liable for what users post on their platforms. However, this protection is conditional upon "Due Diligence." [11]

- **Takedown Notices:** Intermediaries must remove illegal content (e.g., child pornography or content violating national security) within 24 to 36 hours of a court or government order.
 - **Traceability:** Messaging platforms (like WhatsApp) are required to enable the identification of the "First Originator" of a message if requested by a court for serious crimes. This remains a point of legal contention regarding end-to-end encryption.
-

3.8 Summary for Examination

For a complete grasp of this module, remember the "Three Pillars":

1. **IT Act 2000:** The foundation for e-commerce, digital signatures, and technical cyber-crimes (hacking/phishing).
2. **DPDP Act 2023:** The "Privacy Law" that protects the individual through principles of consent, minimization, and heavy penalties.
3. **BNS 2023:** The "Criminal Law" that punishes traditional crimes (harassment/stalking/terrorism) when committed in the digital domain.

Technical Takeaway: As a security engineer, your system's architecture must support **Privacy by Design** (DPDP), provide **Digital Evidence** (BSA), and maintain **MFA/Encryption** (RBI/IT Act) to ensure full legal compliance in the Indian market.